
Dr. Pooja's Physio - Clinical Admin Test Plan

The clinical desk: patients, sessions and care records, and nothing financial

Role

Clinical Admin

Document version

1.0

Audience

A tester checking this role end to end

Environment

Throwaway Supabase project · Razorpay test mode · npm run dev

Read first

Section 1 - who this is, and what has to exist before you start

Contents

1. Who this is, and what must exist first
2. Signing in, and what the screen says you are
3. Today
4. Sessions - manage
5. Recommendations - the heart of this desk
6. People, and the clinical record
7. What Clinical must never reach
8. Suspension, and the scope itself
9. Sign-off

1. Who this is, and what must exist first

The desk. Clinical looks after care: the patients, the sessions they are in, the health records behind them and the recommendations a clinician has written. They see no money at all, they cannot touch the catalogue, they cannot read the activity log, and they cannot change how the product behaves.

What this desk opens, exactly.

Section	Clinical
Today	manage
Sessions	manage
People	manage
Money	none
Catalog	none
Logs	none
Settings	none

Three sections, and it is the narrowest of the four desks. Operations has Catalog as well; Finance has Money and reads Sessions. Clinical has the care and nothing else.

The account.

Label	Email	Password
Clinical	qa.admin.clinical@example.test	generated when the Master Admin creates it

1.1 Before you start

Must exist	Set up by
This Clinical account, created from Settings → User Access	Master Admin
Two patients with health records already filled by a therapist, on different condition types	Therapist
At least one patient with a paid, unassigned session	Patient
A queued recommendation waiting for review	Therapist
One patient with a completed session and a refunded one	Master Admin
Two approved therapists, one with a roster	Master Admin + Therapist
A flagged message - a therapist writing a phone number into a note	Therapist

The refunded session matters. It is what proves this desk cannot read the money on a row it can otherwise fully work. **The flagged message matters too:** it is the one piece of evidence that stays Master-Admin-only even though the rule that produced it is this desk's.

1.2 How to record a result

Mark every step **Pass**, **Fail**, **Blocked** or **N/A**. Raise a failure with: the step id, what you did, what you expected, what happened, a screenshot, any console error in full, how many times out of how many it reproduced, and **which account you were signed in as**.

Severity. P0 - money, clinical data or access control is wrong: stop and report. **P1** - a main journey is broken with no workaround. **P2** - wrong with a workaround. **P3** - cosmetic.

1.3 Calling a route without a terminal

Most refusals here are checked twice - once by the screen hiding a control, once by the route refusing the call - and **only the second is the rule**. Sign in as Clinical, press **F12**, open **Console**, paste and press Enter:

```
const r = await fetch("/api/some/route", {
  method: "POST",
  headers: { "Content-Type": "application/json" },
  body: JSON.stringify({ some: "value" }),
});
({ status: r.status, body: await r.text() });
```

The request is same-origin, so the browser attaches this admin's cookie itself. Use a **second browser profile** for a different account, not a second tab. Never paste the URL in the address bar: that sends a GET, these are POSTs, and you will get 405.

2. Signing in, and what the screen says you are

CL-01 - The dashboard names itself · P2

Do this. Sign in as the Clinical admin.

Expect

- The sidebar brand reads `Clinical`, and the **eyebrow over the section heading** reads `Clinical` too. **Both** - the sidebar collapses to icons and is a closed drawer on a phone, while the header is on every screen at every width. **A dashboard that just says "Admin Panel" is a P2.**

CL-02 - The "Your access" card · P2

Expect a card naming which sections this desk covers. This is the narrowest of the four sidebars, so it is the one most likely to read as a fault - **P2 if the card is absent**.

It carries **no scope name of its own**; the brand and the header both say `Clinical` on that same screen already.

CL-03 - Three sidebar entries, and four are gone · P1

Expect present: Today, Sessions, People.

Expect absent: Money, Catalog, Logs, Settings.

3. Today

CL-04 - Clinical leads with the recommendation queue · P1

Expect

- The headline figure is **the recommendations a patient is waiting on** - this desk's own first question. Operations leads with unassigned sessions, Finance with what is owed.
- **No money figure is anywhere on this screen.** Not unlinked, not greyed - **the page does not compute it.** A rupee figure on a Clinical Today is a **P1**.

CL-05 - "Needs you" agrees with the list under it · P2

Do this. Read the "needs a person" figure, then count the queue rows beneath it.

Expect. They **match**. This desk is where the bug was first noticed: a clinical admin read **23** over a list of **four**, because the figure summed every queue while the list beside it was already filtered to what they could open. **P2 if the two disagree.**

CL-06 - Every quick action lands somewhere you can open · P1

Do this. Tap each quick action and come back.

Expect

- Every one lands on a screen Clinical can open.
- **None lands back on Today.** A link into a section they cannot open falls back silently to the first one they can. With four sections closed, this desk has the most ways to hit it - **a quick action that reloads Today is a P1.**
- No action offers a Money or Catalog destination at all; it is **dropped**, not written carefully.

CL-07 - The global search is filtered the same way · P2

Do this. Search a patient's name, a session code, and a **purchase** code.

Expect

- The patient and the session open.
- The **purchase code is reported as not existing.** A result that opened a screen this desk cannot open would be a dead link that looked like it worked.

CL-08 - Activity is their own desk's · P2

Do this. Open **Today** → **Activity**.

Expect entries whose action belongs to a section this desk can **work** and whose **actor** sits at this desk. It runs **sparse** - in a small clinic the Master Admin does most of the work - which is why **the screen says the list is their desk's** rather than showing an empty panel that reads as "nothing happened". **P2 if it just looks empty.**

This is not the Logs section, and it is the only place this desk reads a record of anything.

CL-09 - Risk: their rules, and the two panels that are not theirs · P0

Do this. Open **Today** → **Risk**.

Expect

- The rules whose domain is **sessions** - a contact leak, an early completion.
- **Not** the money ones: a cash variance and a session completed with no payment belong to Finance.
- **The flagged messages panel is absent, and so is the contact reveal log.** Those quote what a colleague wrote and name every patient contact a therapist opened, and they stay **Master-Admin-only** - even though the rule that raised the signal is this desk's. **Either rendering here is a P0.**
- The **thresholds** are not editable from this desk.
- **No action buttons on the tab.** A flag is never an accusation and never carries a penalty: nothing here suspends an account, holds a payout or hides a therapist. **An action button is a P1** - that separation is what makes running heuristics over clinical data safe at all.
- Open a signal: it **links to the rows behind it**, not to a score.
- Review one with **ok**: **refused**. With a real note: it lands, and **appends** - you cannot edit or delete a review.

4. Sessions - manage

CL-10 - Assigning and scheduling · P1

Do	Expect
Open the unassigned queue from Today	Exactly the rows it counted, with the other filters cleared first
Assign a session	Succeeds
Read the control on a never-assigned session	Tap to assign , not "Reschedule / Reassign"
Reschedule a confirmed session	Succeeds , with the same calendar and hour chips a patient sees
Try a time like 6:52	Cannot be produced at all
Book inside the 12-hour window	Refused, until the override box is ticked

CL-11 - Completing, reopening and cancelling · P1

Do	Expect
Complete a paid session on a therapist's behalf	Succeeds - an admin is subject to neither of the therapist's gates
Reopen a completed session	Succeeds , warning that both sides' ratings are destroyed, and clearing the completion time
Cancel a session	Succeeds

CL-12 - What they cannot see about the money · P0

Do this. Open **All Sessions** and look at a **refunded** session, then at one that was paid.

Expect

- **Neither the amount nor the refund renders**, on the row or in the detail drawer. Compare against the Master Admin's view of the same row in another browser.

- The **clinical** content of the row is all there: patient, therapist, condition, status, notes.

CL-13 - The export follows the screen · P0

Do this. Filter **All Sessions**, then export as **CSV** and as **PDF**.

Expect

- Both offered, both describing the **same filtered rows**.
- **Neither file contains the amount or the refund.** A scope enforced in the markup but not in the file the markup produces is not enforced, and an export is the easiest place to forget it. **Money in this file is a P0.**

CL-14 - The roster · P1

Do	Expect
Open Sessions → Roster	A list of therapists , not a calendar grid
Edit a weekly schedule	Succeeds , in periods rather than hourly cells
Write a date exception	Succeeds - this is an admin capability, and Clinical has Sessions at manage
Set somebody on leave	Succeeds, and the weekly schedule survives intact
Remove hours a session sits in	It names who is affected and says the session stays as booked . P0 if it cancels or moves one

CL-15 - Delivery reads as operations, not money · P2

Do this. Open **Sessions → Delivery**.

Expect. No-show rate, cancellation rate, repeat-booking rate, sessions per therapist - and **no revenue figure among them**. These live under Sessions precisely because a no-show rate is about how the clinic runs, not about its books, which is what lets this desk read them.

5. Recommendations - the heart of this desk

CL-16 - The queue reads as work · P1

Do this. Open **Sessions → Recommendations**.

Expect

- **Oldest first**, aged in words rather than dated.
- Anything past four hours is **coloured**, and Today's inbox row is urgent on **that** count - never on the queue merely being non-empty. A badge that is always on is a badge nobody reads, which is how the one queue with a patient waiting behind it stops being looked at. **P2 if the badge is always red.**
- Each card states **how many sessions or visits that patient already has unused** - the commonest reason to turn one down, and previously invisible without leaving the queue.
- That figure is **stated, never acted on**: a patient with sessions left may well need a different programme, and the clinician has seen them.

CL-17 - The three outcomes · P1

Do	Expect
Approve one, plainly	One tap, no reason required. Taxing an approval with a sentence meaning "fine" is how a reason column fills with "ok" and stops being worth reading - and how a patient waits longer for a recommendation nobody objected to
Turn one down with <code>ok</code>	Refused. Ten characters, for the two outcomes that take something away from somebody
Turn one down with a real reason	The therapist reads it in their feed and on the patient's chart. The reason is the actionable half: "Not approved" says it is gone, and only the reason says what to write instead
Approve one with different numbers	A new version attributed to the clinician and entered by you, with the original left in the thread as superseded. The clinician's version being rewritten is a P0

CL-18 - The catalogue is re-checked before publishing · P1

Do this. Have the Master Admin **re-price** a package that a queued recommendation points at. Then try to approve it.

Expect

- **Blocked**, with a sentence naming the drift. Better you catch it than the patient discovering the clinic's stale data by having their payment refused at the last step of checkout.
- Now **reject** a recommendation whose package moved: **allowed**. Refusing to let you close a thread because its package moved would trap exactly the recommendation that most needs closing.

CL-19 - The offer window is stamped at approval · P1

Do this. Approve a recommendation that has been sitting in the queue, and read its expiry on the patient's screen.

Expect. The window counts from **approval**, not from when the therapist wrote it. **A plan that waited two days reaching the patient with two days already spent is a P1** - it is the plans the clinic took longest over that arrive with the least time on them.

CL-20 - Nothing reaches the patient before it is approved · P0

Do this. With a recommendation still queued, check as the patient:

Where	Expect
Suggested Sessions	Nothing. Not a greyed-out card, not a "pending" chip - absent entirely
Health Profile	The same
Create an order against it from the console	Refused

Hiding a card is presentation; refusing the order is the rule. A patient who can pay for an unapproved recommendation is a P0.

CL-21 - Writing one on a therapist's behalf · P1

Do this. Use the panel that writes a recommendation for a clinician who cannot reach their dashboard.

Expect

- The **same rules as the therapist's own dialog**: the package comes from the admin whitelist, the source has to be a **completed session that therapist ran**, the text is scanned, and **there is no price, session-count or discount field**. A price input is a **P0** - this desk sees no money, and the form must not be where it gets one.
- Programmes are **narrowed to the chosen session's own condition**, and changing the session **drops the draft**.
- **Whose name it goes out in is stated at the button**.
- A mandatory reason.
- With no session to write against or no recommendable package, the panel **still renders and says which of the two is missing**. An admin opens this screen because a patient is waiting: **P2** if it is simply absent.

CL-22 - Withdrawing · P1

Do	Expect
Withdraw an active plan with a real reason	Succeeds
Withdraw a queued one	Succeeds - otherwise the queue holds a thread nobody intends to approve while the patient's one-plan slot stays taken
Withdraw a purchased one	Refused . The patient has paid and the sessions exist; the honest lane is a refund - which is a money screen this desk cannot open, so the refusal has to say so rather than offering a control

6. People, and the clinical record

CL-23 - The directories · P1

Do	Expect
Open People → Patients , open one	Sessions, documents, notes, health record - all there
Read the money on their sessions and purchases	Not rendered
Approve a pending signup	Succeeds
Suspend an account	Succeeds
Reset a password	Succeeds , shown once, never in the log
Open People → Therapists	The directory, with the <code>/team</code> visibility control
Change a therapist's revenue share	No such control - that is money
Open People → Partners , look at the revenue-share editor	Does not render , for the same reason

CL-24 - The health record · P1

Do this. Open a patient's health profile from the directory.

Expect

- The record renders for its **own condition type** - the right seven questions, the right summary card, the right snapshot figures and progress line.
- On an **orthopaedic** patient the Pain Map renders. On a **neurological** or **paediatric** one there is **no body map at all** - not a hidden one, not an empty one.
- Every pain figure reads **out of ten**. A percentage beside an out-of-ten figure in the same strip reads as two different measurements: **P2**.
- **Session notes are not here, and must never be**. They are clinician-only working notes. Check the patient's export too.

CL-25 - Condition change requests - P1

Do this. With a therapist's request to edit a patient's live record waiting:

Do	Expect
Open the request	The proposed values beside the current ones
Approve it	It merges , keeping every answer the incoming condition type does not own. A re-triaged patient losing their previous specialty's record is a P0
Decline one with a reason	The therapist reads it
Grant a therapist edit access	Succeeds

CL-26 - The clinical question bank is not theirs - P1

Do this. Look for a way to reword an intake question, or to remove a condition type from triage.

Expect. There is none - that is **Settings → Clinical Questions**, and this desk has no Settings. Confirm at the route:

```
const r = await fetch("/api/admin/intake-questions", {
  method: "POST",
  headers: { "Content-Type": "application/json" },
  body: "{}",
});
({ status: r.status, body: await r.text() });
```

Expect 403. This is the one refusal in this document that may read as surprising - the questions are clinical - and it is correct: changing them changes what every patient in the product is asked, which is a product behaviour rather than a patient's care.

CL-27 - Delete and impersonation are full scope only · P0

```
const routes = [
  "/api/admin/delete-account",
  "/api/admin/start-impersonation",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect a refusal on both, and no control for either on screen. Both are checked against **full scope directly** rather than through People, precisely so a section scope cannot hand them out. **A 200 on impersonation is a P0 that stops the run** - this desk already reads clinical records, and impersonation would let them write as the patient.

7. What Clinical must never reach

CL-28 - Money, at the screen · P1

Try	Expect
Find Money in the sidebar	Absent
Open the Money URL directly	Refused, and the screen says their scope is why , in one dismissible amber line naming a screen that exists

A silent landing somewhere else is the failure here. The fallback landing somewhere valid is correct; saying nothing about it is not. **P2.**

CL-29 - Money, at the routes · P0

```
const routes = [
  "/api/admin/settle-therapist-payout",
  "/api/admin/refund-session-partial",
  "/api/admin/refund-package",
  "/api/admin/apply-goodwill-discount",
  "/api/admin/grant-session-credits",
  "/api/admin/reverse-session-credit",
  "/api/admin/revive-entitlement",
  "/api/admin/correct-cash-amount",
  "/api/admin/mark-cash-remitted",
  "/api/admin/update-hospital-revenue-share",
  "/api/admin/update-therapist-revenue-share",
  "/api/admin/save-promo-code",
  "/api/admin/expenses",
  "/api/admin/finance",
  "/api/admin/mark-paid-by-cash",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect 403 on every one. Not 404, not 500, and not a 400 that reads as "give me better arguments" - that is a route that checked the body before it checked who was asking. **Any 200 is a P0 that stops the run.**

`grant-session-credits` matters most. It is the override lane that can mint sessions out of nothing. **A clinical desk minting credits is a P0.**

CL-30 - Catalog, at the screen and at the routes · P0

Try	Expect
Find Catalog in the sidebar	Absent
Open the Catalog URL	Refused, with the scope line

```
const routes = [
  "/api/admin/create-treatment-category",
  "/api/admin/update-treatment-category",
  "/api/admin/delete-treatment-category",
  "/api/admin/reorder-treatment-categories",
  "/api/admin/create-package",
  "/api/admin/update-package",
  "/api/admin/create-home-visit-package",
  "/api/admin/create-home-visit-areas",
  "/api/admin/upload-catalog-image",
  "/api/admin/extend-package-expiry",
  "/api/admin/reassign-package-therapist",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect 403 on every one. A clinical desk that could re-price the programmes it recommends would be setting the price of the treatment it prescribes, which is the whole reason a therapist picks a package rather than a price.

CL-31 - Logs, at the screen and at both routes · P0

Try	Expect
Find Logs in the sidebar	Absent
Open the Logs URL	Refused, with the scope line

```
const routes = ["/api/admin/activity-log", "/api/admin/clear-activity-log"];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect 403 on both. Logs is Master Admin's alone. Clinical reads their own desk's work on **Today** → **Activity** instead.

CL-32 - Settings, at the screen and at the routes · P0

Try	Expect
Find Settings in the sidebar	Absent
Open Settings → Clinical Questions by URL	Refused
Open Settings → User Access by URL	Refused

```
const routes = [
  "/api/admin/update-setting",
  "/api/admin/set-admin-scope",
  "/api/admin/set-admin-active",
  "/api/admin/create-account",
  "/api/admin/intake-questions",
  "/api/admin/pain-map-questions",
  "/api/admin/save-mission-principle",
  "/api/admin/debug-reset",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect 403 on every one.

`create-account` is the escalation case. The Back office group is absent from their picker, but that is presentation - the full-only check inside the route is what stops a limited scope minting itself a Master Admin. **A 200 is a P0.**

`debug-reset` is the other. Full scope only. **A limited desk wiping the database is a P0.**

CL-33 - The other roles' doors · P0

```
const routes = [
  "/api/therapist/reveal-contact",
  "/api/therapist/suggest-session",
  "/api/therapist/record-cash-collection",
  "/api/patient/condition-profile/export",
  "/api/hospital/withdraw-referral",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect a refusal on every one. `reveal-contact` particularly: an admin is not the treating therapist, and every reveal is logged against a session's own window.

8. Suspension, and the scope itself

CL-34 - Suspending this admin ends the session · P0

Do this

1. **As the Master Admin**, suspend the Clinical admin.

2. In the Clinical admin's **still-open browser**, reload the dashboard.
3. In the same browser, open a patient's health profile by URL.
4. In the same browser, approve a recommendation from the console.
5. Un-suspend.

Expect

- Step 2: bounced.
- Steps 3 and 4: **refused**. A suspended admin's own routes refuse them too, and the database refuses them as well - the session was ended, not merely redirected away from. **A suspended clinical admin still reading patient records is a P0**: flipping a column without ending the session leaves them reading every patient record indefinitely, because a session cookie reaches the database without passing the screen.
- Step 5 restores them to **Clinical**, not to full and not to a default.

CL-35 - Nobody changes their own scope · P0

```
const r = await fetch("/api/admin/set-admin-scope", {
  method: "POST",
  headers: { "Content-Type": "application/json" },
  body: JSON.stringify({ userId: "YOUR_OWN_ID", scope: "full" }),
});
({ status: r.status, body: await r.text() });
```

Expect a refusal. This landing is a P0 and the most serious finding this document can produce.

9. Sign-off

	Should be
Steps run	35
Pass	
Fail	
Blocked	
N/A	
P0 raised	
P1 raised	

Confirm each of these before signing.

The dashboard says Clinical , twice, and carries the access card	☐
Three sidebar entries; Money, Catalog, Logs and Settings absent	☐
Today leads with the recommendation queue and computes no money figure	☐
The "needs you" figure matched the list beneath it	☐

Every quick action landed somewhere they can open; none fell back to Today	☐
Risk showed their rules, and neither evidence panel	☐
Sessions fully worked: assigned, rescheduled, completed, reopened, rostered	☐
No amount and no refund on screen or in the export	☐
All three recommendation outcomes, with a stale package blocked and a rejection allowed	☐
The offer window stamped at approval	☐
Nothing reached the patient before approval, at the screen and at the route	☐
A recommendation written on a therapist's behalf, with no price field	☐
Health records readable per condition type, with no session note anywhere	☐
A condition change approved and merged , not replaced	☐
No revenue share, no delete, no impersonation	☐
403 on all fifteen money routes, <code>grant-session-credits</code> included	☐
403 on all eleven catalogue routes	☐
403 on both log routes	☐
403 on all eight settings routes, <code>create-account</code> and <code>debug-reset</code> included	☐
Suspension ended the session; the scope came back as Clinical	☐
They could not widen their own scope	☐

Signed **Date**

Build / commit tested

What a clean run of this document proves. That the Clinical scope grants what the grid says it grants and refuses what it says it refuses, at the screen and at the route, on one machine, once. It does not prove the clinical capabilities themselves are correct - that is the Master Admin's and the Therapist's documents - nor that the other two desks are correctly narrowed, each of which has a document of its own.